Preventing Injection

✓ **Key principle:** Treat all user input as data, never as executable code

- **Validate input:** Apply strict server-side validation
- **Separate data from commands:** Never concatenate untrusted input into executable queries
- **Use parameterized queries:** Prefer prepared statements and safe APIs
- **Escape when necessary:** Use interpreter-specific escaping when parameterization is impossible

References

- OWASP Top 10
  https://owasp.org/www-project-top-ten/

- Mozilla Secure Coding Guideline
  https://wiki.mozilla.org/WebAppSec/Secure_Coding_Guidelines

- Node Express - Production Best Practices: Security
  https://expressjs.com/en/advanced/best-practice-security.html